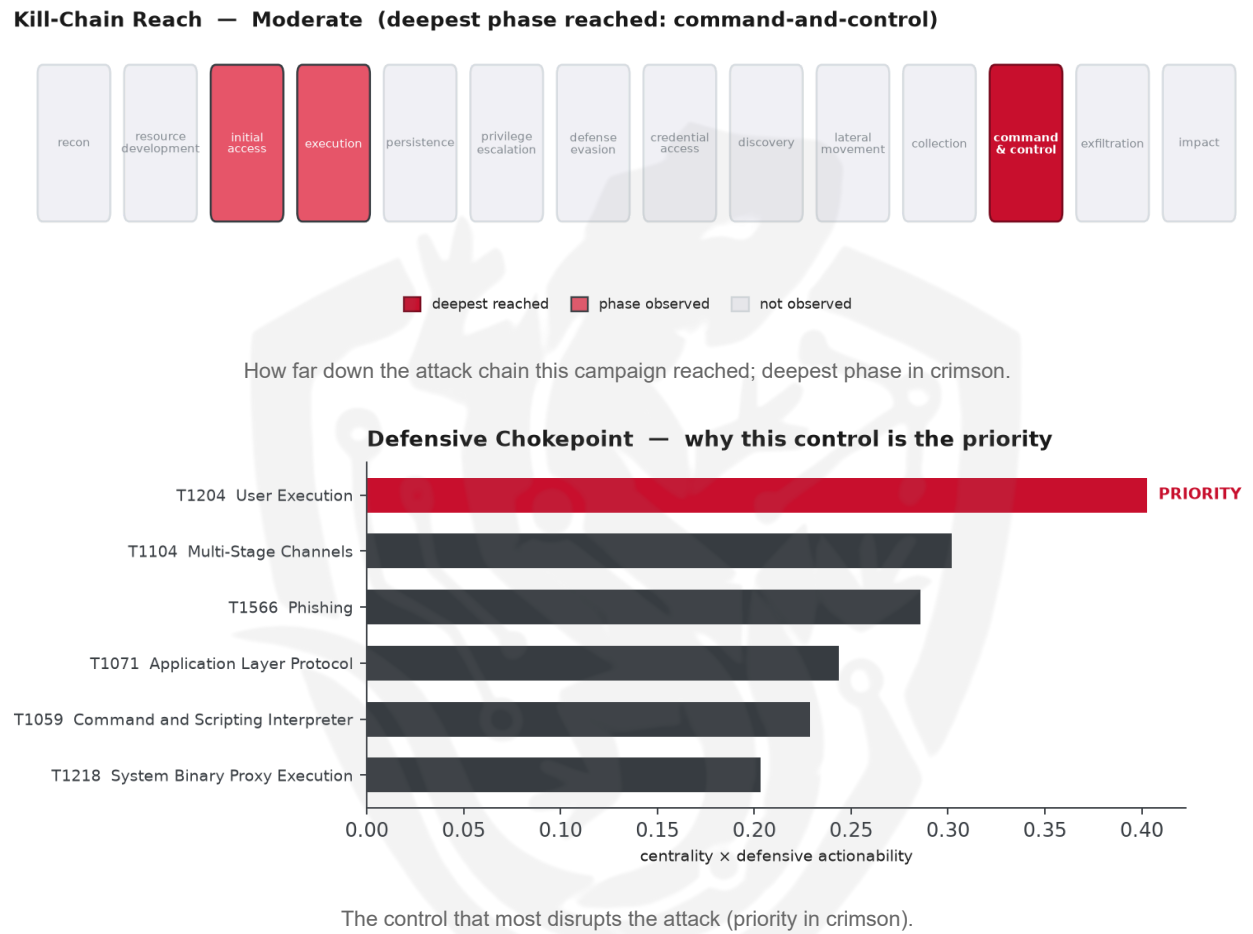


THREAT REPORT: TELEPUZ MALWARE CAMPAIGN

Visual Summary



Summary

The observed cluster of activity involves the spread of TELEPUZ and VIDAR malware, with a focus on exploiting user execution vulnerabilities. The targeted country and sectors are not specified, but the threat is considered moderate, reaching the command-and-control stage. Priority should be given to blocking the execution of downloaded files and enforcing user awareness on lures. The threat actor remains unattributed.

Threat Overview

The observed cluster of activity utilizes the TELEPUZ and VIDAR malware families, although the central CVE exploited is not specified. The techniques inferred from the report include command and scripting interpreter, application layer protocol, multi-stage channels, user execution, system binary proxy execution, and phishing. The victimology is not well-defined due to insufficient data.

Attack Chain and Priority Control

The attack chain involves a series of techniques, including user execution, which is identified as the priority technique. The chain is characterized by the use of various tactics to ultimately gain control over the target system. The priority control is to block execution of downloaded HTA/JS/LNK; enforce mark-of-the-web; disable Office macros from the internet; user awareness on lures.

Infrastructure and Corroboration

There is no corroboration from third-party sources such as abuse.ch or AbuseIPDB, with no hosting providers or ASNs observed, no malware families corroborated, and no indicators at or above 80% confidence.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, machine-extracted from report text — reduced confidence)

The source pulse carried no expert ATT&CK tags, so these techniques were inferred from its narrative by a self-consensus LLM extractor and validated against the ATT&CK catalogue. Treat this technique set, and the chokepoint, kill-chain and risk scores derived from it, as lower-confidence than an expert-tagged brief. - T1059 Command and Scripting Interpreter - T1071 Application Layer Protocol - T1104 Multi-Stage Channels - T1204 User Execution - T1218 System Binary Proxy Execution - T1566 Phishing

Analytical Scores

- Priority technique (graph chokepoint): T1204 User Execution (centrality 0.5033).
- Operational risk: Moderate (score 0.511, reaches command-and-control).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.5103; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Rancor	0.5103

Historical Profile	Behavioural Overlap
Dark Caracal	0.4683
TA459	0.433
TA551	0.4256
APT30	0.4082

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Domain	hurgadatour[.]shop
Domain	cal[.]joycedoula[.]com[.]br
Domain	cal[.]snehamumbai[.]org
URL	hxxps://memshowblob[.]forum/api/index[.]php?a=grab
Hash	03fa348b70819296c958c842e7646b3b7efe5fa217ed5098143003c47995a746
Hash	444f1c0c82b3f6cc31d685bac68b20edbbe5722ce219af9cceab0c2a6537efc1
Hash	580b441e2961739fd26e54e0a0ea08351cb10a51839519fc722cfa39ecd0c954
Hash	58aec6e3835aaf20f7b4a7e308b36a19e7454673a6f71783871e9bcf6cae8eed
Hash	9733a3f6409de81271f21993c7f8b9865ac9f5c68c3d4336e91afe6b312477eb
Hash	a955d7e2819d5fa8b5f879cb970e1a1a91327098a7383f2a03a5e1e7e19435e3
Hash	bf3b4e645a3c0c23f87c55971069014f7424ad14497371ee7567eff68ffaf343
Hash	cee96a38e2dfe31ccf8c3aa7d0d9323e1e3183b2478ba582285822e943d242e9
Hash	ff791fe1532a2dc3b3c188a71bfd0177f973ef228e4d1dda1db6d3c4b0d62b3e

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1204 User Execution (execution)
- **Observed here:** T1204 User Execution was the only execution technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1203 Exploitation for Client Execution (execution)
- **Basis:** of the 36+ groups that use User Execution, this pairing runs 1.5x above base rate, a disproportionately-coupled move rather than the obvious one.

The actor could pivot to T1203 Exploitation for Client Execution in an attempt to bypass the blocked User Execution control, as this technique may allow them to leverage vulnerabilities in client applications to execute malicious code, potentially exploiting trust in commonly used software. This technique in particular could be appealing to the actor because it would likely enable them to target a broader range of systems, including those with more restrictive execution policies. To counter this potential pivot, the mandated defensive control of patching client applications, enabling exploit mitigations such as ASLR, DEP, and CFG, and implementing application isolation should be prioritized.

Also plausible (same tactic): T1053 Scheduled Task/Job (n=42, lift 1.2), T1106 Native API (n=17, lift 1.5)

Detection and hardening for the pivot (T1203 Exploitation for Client Execution)

- **Telemetry:** EDR process + memory telemetry; Office/browser/reader child-process telemetry; Windows Error Reporting (application crashes)
- **Detect:**
 - Office, browser or PDF-reader processes (winword/excel/outlook/acrobat/chrome) spawning shells or LOLBINs
 - Sysmon 1 anomalous children of document/browser apps; unbacked-memory execution right after a client crash
 - WER application-crash events for client apps immediately followed by a new child process
- **Harden:**
 - Patch client software fast (browsers, Office, PDF, Java); retire end-of-life plugins
 - ASR rules blocking Office child processes; exploit protection (DEP/ASLR/CFG) and browser sandboxing
- **MITRE:** M1048 Application Isolation and Sandboxing, M1050 Exploit Protection, M1051 Update Software, M1040 Behavior Prevention on Endpoint · DS0009 Process, DS0011 Module, DS0015 Application Log